Manual de sistemas de Expedientes ETF

Autor: Expedientes ETF. Revisión: 14 de octubre de 2026.

PDF para imprimir. Los anexos de configuración, operación y resolución de problemas forman parte del PDF.

• Requisitos e instalación.

• Arquitectura y contenedores.

• Configuración de producción.

• Arranque y actualización.

• Copias y restauración.

• Cifrado, auditoría, supervisión y conservación.

• Mensajes reales y resolución de problemas.

• Riesgos pendientes de Informática.

• Pruebas de esta revisión.

Este manual está dirigido a Informática de la entidad titular del servicio. Los comandos se ejecutan desde la raíz del repositorio, salvo que se indique otra cosa. La evidencia de F5.05 recoge el ensayo real de restauración. La evidencia de FX2 recoge la actualización de roles en un volumen anterior, la instalación limpia y las comprobaciones de credenciales y permisos. Las reglas de despliegue y conservación están en TRD §§10–14.

Para pruebas en un PC Windows 10/11, utiliza la guía del paquete. `make paquete-windows` prepara imágenes, ZIP versionado y suma SHA-256. El motor principal es Podman Desktop con WSL2; Rancher Desktop con Moby es la alternativa. Crea accesos de escritorio e Inicio con una copia privada del paquete; parar conserva los datos y permite reabrir, desinstalar retira sus accesos y volúmenes. Sólo admite datos inventados. La operación y el alcance comprobado se recogen en WIN1; este paquete no sustituye el despliegue de producción.

La demo local incorpora las nuevas plantillas, idiomas y temas al ejecutar `make demo`, sin borrar sus volúmenes. Comparte con Windows el incorporador de FX8: sustituye la base de la distribución y conserva lo publicado y lo cambiado a mano (§4). `make ci` lo comprueba en una demo desechable con textos y versión de idioma antiguos (FX7 y FX8).

1. Requisitos y responsabilidades

La aplicación es interna. Sólo deben acceder la red corporativa, la red provincial de ayuntamientos y la VPN. No se publica en Internet. El responsable del producto autoriza las versiones y la entrada de datos reales; Informática mantiene máquinas, red, certificados, firmas antivirus, copias y supervisión. Informática no necesita perfil funcional.

Elemento	Requisito
Máquina	Linux con Docker Engine y Compose 2.24.4 o posterior; comprobar `docker version` y `docker compose version`
Preproducción	Recursos según la carga prevista; sólo datos inventados
Producción	Dimensionar CPU, memoria y disco cifrado según el volumen; vigilar crecimiento de base y copias
Base de datos	PostgreSQL 18; Compose fija 18.4 y la huella de imagen
Antivirus	ClamAV local; Compose fija 1.4.3 y su huella; firmas actualizadas mediante suministro local aprobado
Directorio	Active Directory mediante LDAPS, TCP 636, certificado válido y autoridad de confianza de la entidad
Web	Nombre interno y certificado HTTPS; `etf.example.org` es un dominio de ejemplo;

	configurar el propio
Construcción	Git y acceso autorizado al repositorio público; imágenes fijadas en Dockerfile y Compose; npm usa package-lock
Ensayo local	Go 1.26.9, Node/npm, Python 3, curl, OpenSSL y Chrome del sistema; Docker local

La red interna Docker no publica PostgreSQL (5432) ni ClamAV (3310). La app publica por defecto `127.0.0.1:18083`. El proxy HTTPS debe alcanzar ese puerto sin abrirlo a Internet. Si el proxy está en otra máquina, Informática debe preparar una conexión privada y una configuración adicional revisada. La red base tampoco proporciona salida a AD: hay que habilitar sólo el destino LDAPS autorizado. Verificar DNS, rutas, cortafuegos, hora y cadena de certificados.

Compose base permite comprobar el arranque local, pero no instala el proxy HTTPS ni configura el AD corporativo. La demo añade un directorio inventado y una entrada HTTP local; **no se usa en producción**. Quién termina HTTPS, acceso a AD, política de firmas, destino de copias y supervisión siguen pendientes de Informática.

2. Instalación desde el repositorio

1. Obtener la versión autorizada del repositorio público en una carpeta de servicio.

Registrar `git rev-parse HEAD`; no desplegar una rama con cambios sin confirmar.

2. Crear fuera del repositorio `/etc/etf/entorno.env`, propiedad de la cuenta de servicio y permiso 0600. Tomar los nombres de .env.plantilla y generar contraseñas distintas para instalación, migración, aplicación, copias y cálculo de Memoria. No pegar valores en incidencias o Git.

3. Preparar un archivo adicional `/etc/etf/compose.interno.yaml` con los ajustes aprobados de AD, origen HTTPS, certificados y almacenamiento de paquetes.

4. Definir en la sesión de operación esta función; usar siempre los mismos archivos y nombre de proyecto. La ruta del repositorio debe ser absoluta.

```
ETF_REPOSITORIO="$PWD"
componer() {
  docker compose --project-directory "$ETF_REPOSITORIO" \
    --env-file /etc/etf/entorno.env -p etf \
    -f "$ETF_REPOSITORIO/compose.yaml" \
    -f /etc/etf/compose.interno.yaml "$@"
}
componer config --quiet
componer build app migrar
componer up -d --wait --wait-timeout 300 postgres clamav
componer run --rm migrar
componer up -d --no-deps --wait app
componer ps -a
curl --fail http://127.0.0.1:18083/salud
```

No ejecutar `compose config` sin `--quiet`: puede mostrar secretos. Revisar los registros de preparación y migración y exigir salida 0. La app recibe credenciales de `etf_app` y, para las cifras abiertas de Consulta, la credencial de lectura técnica `etf_calculo_memoria`; nunca las de `etf_migrador`, `etf_copia` o instalación. El binario comprueba la conexión a la base, pero no modifica el esquema. La comprobación del historial y sus huellas corresponde al migrador.

Compose ejecuta `preparar-roles` antes de `migrar`, tanto con un volumen nuevo como con uno existente. La preparación crea los roles que falten y sincroniza sus atributos y contraseñas con el entorno privado en una transacción. No toca expedientes, auditoría ni historial de migraciones. Usa el instalador por socket local, sin red ni contraseña TCP. El socket es temporal, con permiso 0700, compartido exclusivamente por PostgreSQL y el servicio de preparación. Si encuentra una pertenencia inesperada de un rol técnico, falla y no arranca el migrador. No ejecutar la actualización con `--no-deps`.

La primera cuenta de Administración funcional no se crea desde Usuarios y permisos:

1. Informática configura `ETF_PRIMER_ADMINISTRADOR` con el login autorizado en el entorno privado y lo entrega a `services.app.environment`.
2. Arranca Compose con sus dependencias. `preparar-roles` prepara los roles técnicos de PostgreSQL; después `migrar` aplica el esquema. Preparar roles no concede perfiles funcionales.
3. La persona autorizada entra con su cuenta de AD. El servidor resuelve su `objectGUID` y ejecuta el alta inicial una sola vez. Perfil de Administración, marca de inicialización y auditoría se confirman juntos.
4. Esa persona concede Administración a una segunda persona autorizada. Desde entonces, cada una pide a la otra los cambios de sus propios perfiles, vigencias, equipo o baja.

Retirar posteriormente todos los administradores no repite el alta inicial. Cambiar la variable o volver a entrar tampoco la repite. Una recuperación requiere una operación expresa y auditada de Informática; no se borra la marca para provocar otra concesión (SEG2, R-10, 14/10/2026).

El archivo adicional debe pasar las variables a `services.app.environment`: ponerlas sólo en el fichero de entorno no las entrega automáticamente al contenedor. Como mínimo, añadir origen HTTPS, las cuatro opciones AD, los límites de sesión si se cambian los valores iniciales y primer administrador de la tabla siguiente. Montar la CA en sólo lectura en la ruta indicada. No copiar certificados privados al repositorio.

Los montajes base de `idiomas/` y `temas/` son de sólo lectura. Para publicar paquetes mediante Administración, el despliegue aprobado debe sustituirlos por almacenamiento persistente escribible por UID/GID 10001, inicializado con el contenido de la versión. Respaldar esos directorios, incluidas todas las versiones de plantillas. La demo usa volúmenes propios y comprueba esta variante. No cambiar permisos de toda la carpeta del repositorio para resolver un fallo de escritura.

Comprobar después por HTTPS: entrada AD, primer administrador, asignación de perfiles, subida con antivirus y descarga Word. El primer administrador se concede una sola vez: cambiar la variable o reiniciar no recupera un perfil retirado.

La configuración de producción incluye los montajes de host, la comprobación LDAPS, el contrato del proxy y la puesta en servicio. El paquete Windows tiene sus propios pasos: comprobar la suma del ZIP, instalar el motor y WSL2, instalar, parar y actualizar con sus lanzadores. «Reiniciar» borra la demo tras confirmación; «Parar» conserva los datos. Informática no debe cargar expedientes reales en ese paquete.

3. Variables de configuración

Variables	Uso y valor inicial
`ETF_INSTALADOR_CONTRASENA`	Inicialización del volumen PostgreSQL; su contraseña se retira al crear los roles
`ETF_APP_CONTRASENA`, `ETF_MIGRADOR_CONTRASENA`, `ETF_COPIA_CONTRASENA`	Contraseñas distintas; inicialización y preparación las aplican a los roles y cada consumidor recibe sólo la suya
`ETF_CALCULO_MEMORIA_CONTRASENA`	Contraseña propia de lectura técnica para las cifras abiertas de Consulta, sin membresías, propiedad ni BYPASSRLS. PostgreSQL, preparación y app reciben la misma variable. Si falta o está vacía, el rol queda sin contraseña y sin inicio de sesión; no queda una credencial anterior activa
`ETF_HTTP_PUERTO`	Publicación local, 18083 por defecto
`ETF_RED_SUBRED`, `ETF_ENTRADA_SUBRED`	Redes Docker; elegir rangos privados sin colisión
`ETF_HTTP_DIRECCION`	Escucha de la app; Compose usa `0.0.0.0:8080`
`ETF_HTTP_ORIGEN`	Origen HTTPS exacto, sin ruta; debe coincidir con el acceso del navegador
`ETF_HTTP_PROXIES`	Redes CIDR, separadas por comas, de los proxies HTTPS que reenvían a la app (como `10.250.4.17/32`). Sólo de ellas se acepta `X-Forwarded-For`, y el proxy debe sustituir esa cabecera por la IP del cliente, no añadirla. Si se deja vacía con un proxy

	delante, el límite de intentos cuenta a todo el personal como un único origen
`ETF_BD_HOST`, `ETF_BD_PUERTO`, `ETF_BD_NOMBRE`, `ETF_BD_USUARIO`, `ETF_BD_CONTRASENA`	App: postgres, 5432, etf, etf_app; contraseña tomada de `ETF_APP_CONTRASENA`
`ETF_BD_MAX_CONEXIONES`	Máximo de conexiones de la app: 4 por defecto, entre 1 y 64; la conexión de cálculo tiene su propio pool
`ETF_BD_SSLMODE`, `ETF_BD_SSLROOTCERT`	`disable` en la red privada de Compose; sólo se admite también `verify-full`, con CA y PostgreSQL preparado para TLS. El migrador de Compose no configura TLS
`ETF_MIGRACIONES_RUTA`	Ruta de manifiestos del migrador; la imagen incluye `/opt/etf/migraciones`
`ETF_AD_URL`	URL `ldaps://` del controlador autorizado
`ETF_AD_BASE_DN`	Base de búsqueda del directorio; confirmar con Informática
`ETF_AD_FORMATO_BIND`	Formato con marcador `{usuario}`; confirmar que permite leer `objectGUID`
`ETF_AD_CA_RUTA`	Ruta dentro del contenedor al certificado público de la autoridad
`ETF_SESION_MAXIMA`	Duración absoluta en formato Go; por defecto `8h`, con tope técnico `24h` y nunca menor que la inactividad. Decisión del responsable del producto del 14/10/2026. No se prolonga al continuar la sesión
`ETF_SESION_INACTIVIDAD`	Por defecto `30m`; debe superar `2m` para permitir el aviso. La interfaz avisa dos minutos antes y permite continuar; al caducar vuelve a la entrada conservando los datos guardados. Configurar ambas variables en `services.app.environment` si se cambian
`ETF_PRIMER_ADMINISTRADOR`	Login de la persona autorizada para el alta inicial
`ETF_CLAMAV_DIRECCION`	`clamav:3310` en Compose
`ETF_IDIOMAS_RUTA`, `ETF_TEMAS_RUTA`	`/datos/idiomas`, `/datos/temas` en Compose
`ETF_IDIOMA`, `ETF_TEMA`	`es`, `expedientes-etf`

Los tiempos de AD (5 segundos), ClamAV (45 segundos en el arranque) y parte de los límites de subida están fijados actualmente en los adaptadores. TRD prevé ampliar la configuración; no hay que inventar variables para cambiarlos. No hay variables SMTP ni servicio de correo: la aplicación no envía avisos por correo. Los avisos se consultan dentro de ella. No configurar una cuenta de correo.

`ETF_MODO=desarrollo` pertenece a la demostración, no a producción.

4. Arranque, parada y actualización

Arrancar: `componer up -d --no-deps --wait app`, con PostgreSQL, ClamAV y esquema previamente comprobados. Parar escrituras: `componer stop app`. Parar el conjunto: `componer down`; conserva los volúmenes. **No usar `down --volumes` en producción.**

Para actualizar, reservar una ventana y avisar a los equipos. Registrar versión anterior, configuración y huellas de imágenes. Parar app y tomar copia de base y paquetes como en §5. Guardar la imagen anterior antes de reconstruir la etiqueta. Obtener la nueva versión autorizada, construir app y migrador y ejecutar `componer run --rm migrar`, conservando sus dependencias. La preparación de roles se ejecuta antes de migrar también al actualizar un volumen anterior a F4.07: no hay que ejecutar `habilitar_calculo_memoria.sh` a mano. Añadir la contraseña propia de cálculo al entorno privado si se va a habilitar esa conexión. No editar SQL ya aplicado ni ejecutar manualmente sus archivos: el migrador comprueba huellas, dependencias y orden por módulo; rechaza retrocesos.

Si migrar termina correctamente, arrancar app y comprobar salud, acceso, ficha y Word. Si falla, mantener cerrada la entrada, conservar registros y comprobar qué migraciones quedaron aplicadas. No asumir que fallar un paso revierte todo el lote. Para volver atrás, usar la imagen anterior; si no entiende el esquema nuevo, restaurar la copia previa y los paquetes de esa misma versión antes de abrir. Se perderían escrituras posteriores a la copia:

comunicarlo y reconciliarlas. Idiomas y temas (FX8): la actualización sustituye la base de la distribución y conserva lo publicado por Administración (todo lo que cuelga de `.versiones`) y los ficheros cambiados a mano, que se avisan. Sólo se retira un fichero que la entrega nueva ya no trae si lo instaló la entrega anterior, según su manifiesto, y no se ha tocado; las copias manuales se conservan. Si después los textos no cargan, por JSON dañado o claves repetidas, la aplicación no arranca y el diagnóstico indica fichero y clave. Reinstalar la versión anterior del paquete no devuelve la base a su estado previo, porque su incorporador no sustituye ficheros existentes. Para volver atrás, restaurar la copia previa de los volúmenes de idiomas y temas (§5) junto con la base de datos, o reinstalar con el actualizador nuevo.

TRD exige automatizar copia, salud y vuelta atrás; Compose base no aporta todavía esa automatización completa. Este manual describe la operación supervisada.

5. Copias y restauración

Hacer copia diaria cifrada fuera del servidor y otra antes de cada actualización. TRD tolera como máximo un día de pérdida y una parada de unas horas. Informática fija destino, retención de copias, cifrado, custodios y alarmas. La conservación de expedientes durante 25 años no implica guardar todas las copias durante 25 años. Una copia no está validada hasta comprobar su restauración.

El conjunto recuperable incluye: base PostgreSQL, todas las versiones de idiomas, catálogos de archivos, plantillas y temas, versión de imágenes/código, configuración externa y certificados necesarios. Los secretos se custodian por separado. Las firmas antivirus se pueden reponer desde el suministro local aprobado.

Con app parada y directorio de copia en almacenamiento cifrado, permisos 0700:

```
umask 077
ETF_COPIA_DIR=/ruta/cifrada/etf/copia-previa
mkdir -p "$ETF_COPIA_DIR"
componer exec -T postgres pg_dump -U etf_instalador -d etf -Fc > "$ETF_COPIA_DIR/etf.dump"
componer exec -T postgres pg_restore --list < "$ETF_COPIA_DIR/etf.dump" > /dev/null
```

Comprobar ambos códigos de salida. El rol `etf_copia` tiene `BYPASSRLS`, pero el ensayo detectó que carece de lectura en algunas tablas (primero `catalogo.smi`). No dar por operativa una copia con ese rol hasta completar y probar sus permisos en una tarea SQL independiente. Estos comandos usan al operador local `etf_instalador`, que incluye todos los equipos. No usar `etf_app`, que podría omitir datos o fallar por la seguridad por filas. Aquí se usa el socket local del contenedor, accesible sólo al operador de Docker; no se expone al exterior ni exige imprimir contraseñas. El anexo de operación concreta el cifrado y la verificación del conjunto. El formato personalizado contiene objetos, propietarios, permisos, datos y secuencias. No contiene roles globales ni los permisos de la propia base al no usar `--create`.

Copiar los directorios persistentes de idiomas y temas con app parada, conservando permisos y todas las versiones. En montajes de host: `tar -cf` desde el directorio que contiene ambos. En volúmenes: montar los mismos volúmenes en un contenedor puntual sin red y usar tar. El script de ensayo usa los volúmenes de la demo. Registrar sumas SHA-256 y tamaño; trasladar al destino cifrado fuera del servidor y comprobar la recepción. Un archivo `.dump` sin cifrar no cumple la política de copias.

Antes de restaurar, parar `app` y la entrada. No abrirlas hasta completar el paso de revisión. Con la base vigente todavía disponible, exportar la lista completa de identidad a un fichero custodiado por Informática, fuera del volumen y de la copia que se va a restaurar:

```
umask 077
componer exec -T postgres psql -XAt -v ON_ERROR_STOP=1 -U etf_instalador -d etf \
  -c 'SELECT identidad.exportar_identidad();' > identidad-vigente.json
```

Conservar el fichero sin permisos para otras personas y verificar que contiene la lista completa. Tiene nombres y permisos del personal; no enviarlo por correo ni añadirlo al repositorio. Si la base vigente se ha perdido, recuperar una exportación reciente custodiada fuera del servidor y contrastarla con el Programa. Si no hay una referencia fiable, mantener la aplicación parada. La base restaurada debe incluir la migración `identidad/0004` y la imagen de la aplicación debe incorporar SEG4. Para una copia anterior, aplicar primero las migraciones con el ejecutor separado y usar una imagen compatible que incluya la revisión, sin abrir la aplicación.

Restaurar primero en una máquina aislada, con la misma versión PostgreSQL 18 y roles inicializados desde Compose; no importar un volcado desconocido. Parar app y cerrar acceso del proxy. Conservar copia del estado dañado para investigar. Los siguientes comandos **borran la base `etf` del proyecto elegido**; revisar destino, copia y autorización de la intervención antes de ejecutarlos:

```
componer exec -T postgres dropdb -U etf_instalador etf
componer exec -T postgres createdb -U etf_instalador -O etf_propietario etf
componer exec -T postgres pg_restore -U etf_instalador -d etf \
  --exit-on-error < "$ETF_COPIA_DIR/etf.dump"
componer exec -T postgres psql -X -v ON_ERROR_STOP=1 -U etf_instalador -d postgres \
  -c 'REVOKE ALL ON DATABASE etf FROM PUBLIC;
      GRANT CONNECT ON DATABASE etf
      TO etf_app, etf_migrador, etf_copia, etf_calculo_memoria;'
```

Restaurar idiomas y temas de esa copia, con sus propietarios y permisos. Verificar migraciones, cantidades por equipo, secuencias, cadena de auditoría y referencias de paquetes. Tomar la fecha de la copia del registro de la operación de copia, con su zona horaria; no usar la fecha del fichero restaurado. Antes de arrancar, activar la revisión obligatoria:

```
set -o pipefail
python3 -B scripts/preparar-revision-restauracion.py \
  --referencia identidad-vigente.json --fecha-copia '2026-10-14T08:00:00+02:00' | \
  componer exec -T postgres psql -X -v ON_ERROR_STOP=1 -U etf_instalador -d etf
```

Comprobar que ambos comandos terminan correctamente. Si falla cualquiera, no arrancar. El paso crea una marca persistente, compara altas, bajas, perfiles y equipos por el identificador estable de AD, borra todas las sesiones restauradas y registra la operación. La aplicación no puede ejecutar este paso. Una repetición crea otra revisión, anula la anterior y vuelve a cerrar las sesiones. Se exige al menos una persona administradora activa en ambas listas; si falta, Informática y el responsable del Programa deben recuperar una identidad administrativa válida antes de repetir, dejando constancia de la operación. No se concede un perfil por cambiar la configuración de arranque.

Arrancar la imagen correspondiente y la entrada, sin sembrar de nuevo. Sólo Administración funcional puede entrar, con AD y permisos vigentes en ambas listas. La única pantalla disponible es «Revisión tras restaurar una copia». Muestra la fecha de la copia y los permisos de la copia frente a los anteriores a la restauración. Administración aplica o descarta cada cambio; descartar conserva los permisos de la copia, incluso si se habían retirado después. Si un equipo de destino falta en la copia, Informática debe recuperarlo antes de aplicar, o Administración descarta el cambio conscientemente. Las altas pendientes siguen pendientes. Otra persona de Administración debe aplicar los cambios de tus propios perfiles o equipo; no puedes aplicarlos a tu cuenta.

Hasta decidir todos los cambios y confirmar la revisión, el resto del personal no puede entrar y las demás funciones permanecen cerradas. Cada decisión y la confirmación quedan auditadas. Tras confirmar, comprobar acceso de cada perfil, aislamiento entre equipos, ficha y generación Word. Comparar también la cadena de auditoría con el último sello guardado fuera del servidor mediante el comprobador local. Registrar hora, copia y pérdida de datos; retirar la exportación temporal según la política de custodia.

Ensayo reproducible local, sólo con datos inventados del worktree:

```
make demo
python3 -B scripts/ensayar-restauracion.py
```

El script no admite nombres de proyectos externos. Serializa operaciones con la demo y copia mediante el operador local. Recupera paquetes con el preparador puntual `incorporar`, sin red, para conservar permisos y UID/GID originales sin dar privilegios a app. Borra realmente la base y el contenido de idiomas y temas, restaura y compara todos los datos y secuencias y el contenido y permisos de los paquetes. Antes de copiar y después de restaurar ejecuta el recorrido de Anexo 3 a Acta con Chrome del sistema; también comprueba los siete accesos de la demo. Así verifica que las referencias de la base resuelven los archivos recuperados. Las copias quedan en `TMPDIR`, con permiso privado; se borran sólo tras éxito. Si falla después de anunciar la ruta de copia, conservarla y recuperar desde ella antes de limpiar la demo. Un fallo del recorrido previo no llega a crear la copia. Es un ensayo lógico local; no acredita cifrado, traslado ni recuperación de un disco perdido. Repetirlo en preproducción con el sistema corporativo antes de datos reales.

6. Salud, registros y firmas antivirus

Usar `componer ps -a`, `componer logs --tail 100 app migrar` y `curl --fail http://127.0.0.1:18083/salud`. Docker comprueba esa misma ruta. Ahora `/salud` informa del estado básico de la base y avisos de configuración; HTTP 200 no demuestra acceso AD ni firmas recientes. TRD prevé una salud detallada y rutas separadas de vivo/listo; no están disponibles en esta versión. Añadir comprobaciones operativas de LDAPS, antigüedad de firmas, disco, copia diaria, restauración periódica y caducidad de certificados. La política y el receptor de alertas se concretan con Informática.

Los registros Docker usan controlador local, máximo 10 MB por archivo y tres archivos por contenedor. Revisar códigos técnicos sin adjuntar cuerpos HTTP, contraseñas, nombres, contactos ni textos de fichas. La auditoría funcional queda encadenada en PostgreSQL; no se sustituye por logs Docker. Restringir acceso y exportar sólo por el procedimiento autorizado.

ClamAV no ejecuta FreshClam ni descarga firmas. El volumen se rellena al crearlo; cambiar la imagen no actualiza un volumen existente. Informática debe reponer firmas desde su fuente local y reiniciar ClamAV, verificar `PONG`, fecha de firmas y un ensayo antivirus aprobado. Las firmas de la imagen local pueden estar antiguas. Si ClamAV no responde, el anexo permite continuar con aviso y auditoría; plantillas, paquetes y hojas de carga necesitan revisión satisfactoria. Supervisar ese estado.

7. Rotación de claves y certificados

En ventana de mantenimiento, parar app y los procesos de migración/copia. Actualizar las contraseñas en el gestor o fichero externo privado y ejecutar `componer run --rm preparar-roles`. El guion aplica las contraseñas a los roles existentes; repetirlo es seguro. Recrear los servicios consumidores y verificar conexiones y una copia nueva. Una contraseña de cálculo vacía deshabilita ese inicio de sesión y elimina su contraseña anterior. No poner `ALTER ROLE ... PASSWORD` con una contraseña literal en el historial. Mantener `etf_instalador` sin contraseña TCP. El acceso al grupo Docker equivale a administración del servidor: restringirlo.

Renovar el certificado HTTPS en el proxy decidido por Informática, comprobar nombre, cadena y fecha y recargarlo. Para cambiar la CA de AD, montar la cadena nueva en sólo lectura, recrear app y probar el acceso; nunca desactivar la validación TLS. La aplicación genera identificadores aleatorios de sesión y la clave CSRF al arrancar: no existe una variable de clave de firma que el operador deba rotar. Tras una sospecha de robo de sesiones, revocarlas según el procedimiento de identidad; reiniciar por sí solo no garantiza borrarlas de PostgreSQL. Rotar claves de cifrado de copias con la herramienta corporativa conservando la capacidad de descifrar las copias retenidas y ensayando la recuperación.

8. Datos guardados y ubicación

Ubicación	Contenido
Volumen `postgres_datos`, montado en `/var/lib/postgresql`	Familias, adultos, menores, contactos, intervención, evaluaciones, episodios, comisiones, informes, emisiones, metadatos y referencias de versiones, usuarios/perfiles/equipos, huellas de sesiones, migraciones y auditoría
`/datos/idiomas`	Textos, catálogos y versiones inmutables de plantillas Word y paquetes de idioma
`/datos/temas`	Manifiestos, tokens, fuentes y recursos de las versiones de temas
Volumen `clamav_firmas`	Firmas antivirus, no documentos de expedientes
Docker, controlador local	Registros técnicos limitados; no deben contener datos personales
Configuración fuera de Git	Contraseñas, parámetros del entorno y material de certificados

Los anexos recibidos, las actas de carga, las hojas y los documentos generados se procesan en memoria y se descartan; no hay archivo documental de expedientes. Las plantillas administradas sí se conservan. No se guardan contraseñas de AD. Los documentos que una persona descarga quedan bajo la custodia de su equipo,

fuera de la app. La conservación prevista es de 25 años desde el cierre, con retirada de datos personales revisada por dos personas distintas de Administración funcional. El procedimiento técnico y sus límites están en el anexo de operación. La copia debe respetar ese procedimiento y los plazos aprobados; una restauración no debe reintroducir datos ya eliminados sin revisión.

9. Incidentes

Registrar hora, síntomas y versión sin copiar datos personales. Avisar a Informática y responsable del producto; involucrar al DPD y al responsable de seguridad si hay exposición o pérdida de datos. Aplicar el procedimiento corporativo y sus plazos, sin fijarlos aquí.

Ante acceso indebido, cerrar la entrada web, conservar base y logs con acceso restringido, revocar cuentas/sesiones afectadas y rotar secretos comprometidos. No limpiar volúmenes ni ejecutar otra siembra. Ante pérdida de base, detener app, identificar la última copia verificada y seguir §5. Ante fallo AD, comprobar red, hora y certificados; no sustituirlo por acceso sin contraseña. Ante ClamAV caído, restablecer daemon y firmas y revisar los anexos admitidos con aviso. Ante disco lleno, ampliar almacenamiento o retirar sólo registros/copias conforme a retención; no borrar archivos PostgreSQL manualmente.

Documentar alcance, recuperación y comprobaciones. Abrir de nuevo con autorización de los responsables. Revisar causa y repetir la prueba que falló.

10. Lista de comprobación para producción

• [ ] Máquina, disco cifrado, hora, DNS y acceso administrativo restringido.

• [ ] Versión autorizada, imágenes fijadas y sin cambios locales pendientes.

• [ ] HTTPS y certificados válidos; acceso sólo corporativo, provincial y VPN.

• [ ] LDAPS autorizado y `objectGUID` comprobado; límites de sesión comprobados (30 minutos sin actividad y 8 horas absolutas por defecto).

• [ ] Secretos externos con permiso 0600; separación de roles y app sin migrador.

• [ ] Migraciones aplicadas por su ejecutor; salud y pruebas funcionales aprobadas.

• [ ] Almacenamiento persistente de paquetes, versiones anteriores y permisos probados.

• [ ] ClamAV con firmas recientes y suministro local supervisado.

• [ ] Copia diaria cifrada fuera del servidor, alarmas y restauración corporativa ensayada.

• [ ] Vuelta atrás preparada y probada con imágenes, base y paquetes de la misma versión.

• [ ] EIPD aprobada por el DPD y revisión completa de seguridad sin fallos graves.

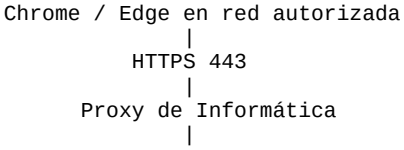
• [ ] Perfiles y aislamiento de equipos verificados; auditoría y conservación revisadas.

• [ ] Supervisión, responsables y procedimiento de incidentes acordados.

• [ ] el responsable del producto acepta el despliegue antes de introducir expedientes reales de 2026.

11. Arquitectura y contenedores

El navegador carga la interfaz React y llama a la API Go del mismo origen. Go sirve la interfaz y conecta con PostgreSQL, Active Directory y ClamAV. Es un monolito modular: las reglas de negocio están separadas de HTTP, SQL, lectura de anexos y generación Word mediante puertos y adaptadores. No hay que instalar un servidor independiente por módulo ni un servidor Node en producción.



```
      127.0.0.1:18083
             |
          app Go :8080
          |      |      |
   PostgreSQL  ClamAV  AD por LDAPS
       :5432    :3310      :636

Instalación y actualización:
PostgreSQL -> preparar-roles -> migrar -> app
```

Servicio de Compose	Función y permanencia	Datos y acceso
`postgres`	Base PostgreSQL 18.4; permanece encendida	UID/GID 70:70; volumen `postgres_datos`; sin puerto publicado
`preparar-roles`	Orden puntual antes de migrar y al rotar contraseñas	UID/GID 70:70; sólo socket privado `postgres_socket`; sin red
`migrar`	Orden puntual con `etf_migrador`; aplica dependencias y huellas	Imagen con SQL y manifiestos; no comparte credenciales con app
`app`	API, interfaz, identidad, cifras y Word	UID/GID 10001:10001; paquetes persistentes; único puerto local publicado
`clamav`	Antivirus local para subidas	UID 100, GID 101; volumen de firmas de sólo lectura; sin puerto publicado

Las raíces son de sólo lectura, sin capacidades Linux y con `no-new-privileges`. Compose limita procesos, CPU y memoria: PostgreSQL 512 MiB, app 256 MiB, migrador 128 MiB, preparación 64 MiB y ClamAV 2 GiB. Estos límites no sustituyen la prueba de carga; vigilar reinicios y falta de memoria antes de cambiarlos. `GOMEMLIMIT=192MiB` fija el objetivo de memoria del proceso Go.

`interna` no tiene salida al exterior. `entrada` permite publicar app en el host, pero desactiva el enmascaramiento de salida. El acceso a AD requiere la conexión privada que prepare Informática. El puerto de PostgreSQL nunca se abre para que funcione el navegador. Las redes, el proxy y sus reglas aprobadas se conservan con la configuración externa.

El rol `etf_propietario` posee el esquema y no inicia sesión. `etf_migrador` puede asumirlo durante la migración; `etf_app` queda sujeto a permisos y seguridad por filas. `etf_calculo_memoria` sólo calcula las cifras autorizadas para Consulta; no tiene `BYPASSRLS`. `etf_copia` tiene ese atributo técnico, con los permisos incompletos indicados en §5. `etf_instalador` queda para operación por socket local y sin contraseña TCP. Restringir Docker: quien accede a él puede leer la base.

No hay caché de expedientes en la aplicación instalada en escritorio. Su aviso sin conexión no permite trabajar fuera de línea. No se deben esperar correos, firma electrónica ni registro automático externo en esta versión.

12. Riesgos abiertos que dependen de Informática

El registro de riesgos del informe de seguridad de cada instalación recoge los riesgos y responsables. Esta revisión del manual no los da por cerrados.

Riesgo	Actuación sobre esta aplicación	Evidencia necesaria
R-01, HTTPS e IP del cliente	Decidir proxy, certificado, HSTS, conservación de `Origin`, sustitución de `X-Forwarded-For` y límites de rutas públicas	Acceso desde cada red autorizada, rechazo desde otra y dos clientes con límites independientes
R-02, copias	Programar copia diaria cifrada fuera del servidor, custodiar claves y ensayar restauración en preproducción	Archivo recuperado del destino real, descifrado y recorrido de acceso, fichas y Word
R-04, coste de rutas públicas	Limitar conexiones y peticiones por cliente en el proxy, coordinado con las mejoras de desarrollo	Prueba de carga sin impedir el uso normal
R-05, sello de auditoría	Coordinar el sellado diario y custodiar ID y huella en un registro independiente de sólo adición	Comprobador contra sello externo; tarea programada y alarma si no hay sello
R-06, AD	Confirmar principal de bind, búsqueda y	Prueba con cuenta autorizada, renombrada y login

	`objectGUID` sobre la misma cuenta	reutilizado; coordinar corrección con desarrollo
R-07, antivirus	Suministrar y supervisar firmas locales; acordar tratamiento de anexos admitidos sin revisión	Firmas recientes, `PONG` y ensayo aprobado de rechazo de fichero infectado
R-12, imágenes	Coordinar actualización de versiones y huellas con desarrollo	Análisis local de imágenes y preproducción; conservar artefacto anterior
R-14, red y rol de copia	Revisar red de ClamAV, reglas `pg_hba` del rol de copia y registro seguro de fallos de conexión	Permisos y conexiones ensayados sin publicar 5432 ni registrar datos personales
R-22, recuperación de permisos	Invalidar sesiones y reconciliar bajas, perfiles y equipos posteriores a la copia	Prueba de que una persona trasladada no recupera el acceso a su equipo anterior

Antes de datos reales siguen pendientes el visto bueno del responsable del producto, el criterio del DPD sobre conservación y vínculos de auditoría, la prueba en preproducción y la caducidad máxima de sesión. Informática aporta operación y evidencias; no resuelve esas decisiones modificando SQL o concediéndose un perfil funcional.

13. Preparar el PDF

Desde la raíz del repositorio, con Python 3, Pillow y LibreOffice local:

```
TMPDIR="$PWD/bin/temporales" python3 -B docs/manuales/exportar.py \
  --manual sistemas --salida docs/sistemas
```

El PDF incluye este manual y los anexos de configuración, operación, diagnóstico y evidencia MANSIS. Las evidencias históricas F5.05, FX2 y WIN1 siguen enlazadas por separado. Sin `--manual`, el exportador conserva los tres manuales de usuario existentes. Para compartir el PDF, acompáñalo del árbol de documentación si se necesitan los enlaces a otros archivos; el PDF no los incorpora como adjuntos.

Anexo A. Configuración de producción

Autor: Expedientes ETF. Revisión: 14 de octubre de 2026.

Volver al manual. Este anexo se usa con la función `componer` del manual, que fija proyecto, repositorio y archivos externos. El Compose base no incluye el proxy de producción ni la conectividad con AD.

A.1 Preparar entorno y secretos

Informática conserva `/etc/etf/entorno.env` fuera de Git, con permiso 0600 y propietario de servicio. Añade las variables de identidad a las contraseñas de la plantilla base. El origen, los límites de sesión, el DN, el formato de bind y el nombre de administrador deben tener los valores aprobados. Las variables LDAP son `ETF_AD_URL`, `ETF_AD_BASE_DN`, `ETF_AD_FORMATO_BIND` y `ETF_AD_CA_RUTA`. No hay contraseña de cuenta de servicio AD configurable en la implementación actual: el acceso usa la contraseña de quien entra y no la guarda.

Genera cada contraseña de base por separado, con `openssl rand -hex 32`, y guárdala en el gestor o archivo privado. No reutilices la del instalador. Evita mostrar el entorno completo, utilizar `set -x` o pegar una salida de `compose config` en soporte. Si se opta por secretos Docker, hay que adaptar su lectura: esta versión consume variables, no ofrece variantes `_FILE` para contraseñas. Montar un secreto sin esa adaptación no configura la aplicación.

A.2 Archivo adicional de Compose

Este contenido corresponde al archivo `/etc/etf/compose.interno.yaml` del manual. Los valores se leen del entorno privado; no escribas las contraseñas en él. La CA pública debe existir en `/etc/etf/certificados/ad-ca.pem`.

```
services:
  app:
    environment:
      ETF_HTTP_ORIGEN: ${ETF_HTTP_ORIGEN:?}
      ETF_HTTP_PROXIES: ${ETF_HTTP_PROXIES:?}
      ETF_AD_URL: ${ETF_AD_URL:?}
      ETF_AD_BASE_DN: ${ETF_AD_BASE_DN:?}
      ETF_AD_FORMATO_BIND: ${ETF_AD_FORMATO_BIND:?}
      ETF_AD_CA_RUTA: /certificados/ad-ca.pem
      ETF_SESION_MAXIMA: ${ETF_SESION_MAXIMA:-8h}
      ETF_SESION_INACTIVIDAD: ${ETF_SESION_INACTIVIDAD:-30m}
      ETF_PRIMER_ADMINISTRADOR: ${ETF_PRIMER_ADMINISTRADOR:?}
    volumes:
      - type: bind
        source: /etc/etf/certificados/ad-ca.pem
        target: /certificados/ad-ca.pem
        read_only: true
        bind:
          create_host_path: false
      - type: bind
        source: /srv/etf/paquetes/idiomas
        target: /datos/idiomas
        bind:
          create_host_path: false
      - type: bind
        source: /srv/etf/paquetes/temas
        target: /datos/temas
        bind:
          create_host_path: false
```

Compose combina montajes por destino: estos dos sustituyen los de sólo lectura de la base. El archivo todavía necesita la solución de red hacia AD aprobada por Informática. No basta con añadir una URL LDAPS. No se usa el archivo de la demo para proporcionar esa red ni para desactivar HTTPS en producción.

A.3 Inicializar idiomas, temas y plantillas

Antes del primer arranque, crea ambos directorios persistentes vacíos y copia el contenido completo de `idiomas/` y `temas/` de la versión autorizada. Requiere administración del host; ejecuta estas órdenes sólo en la instalación nueva:

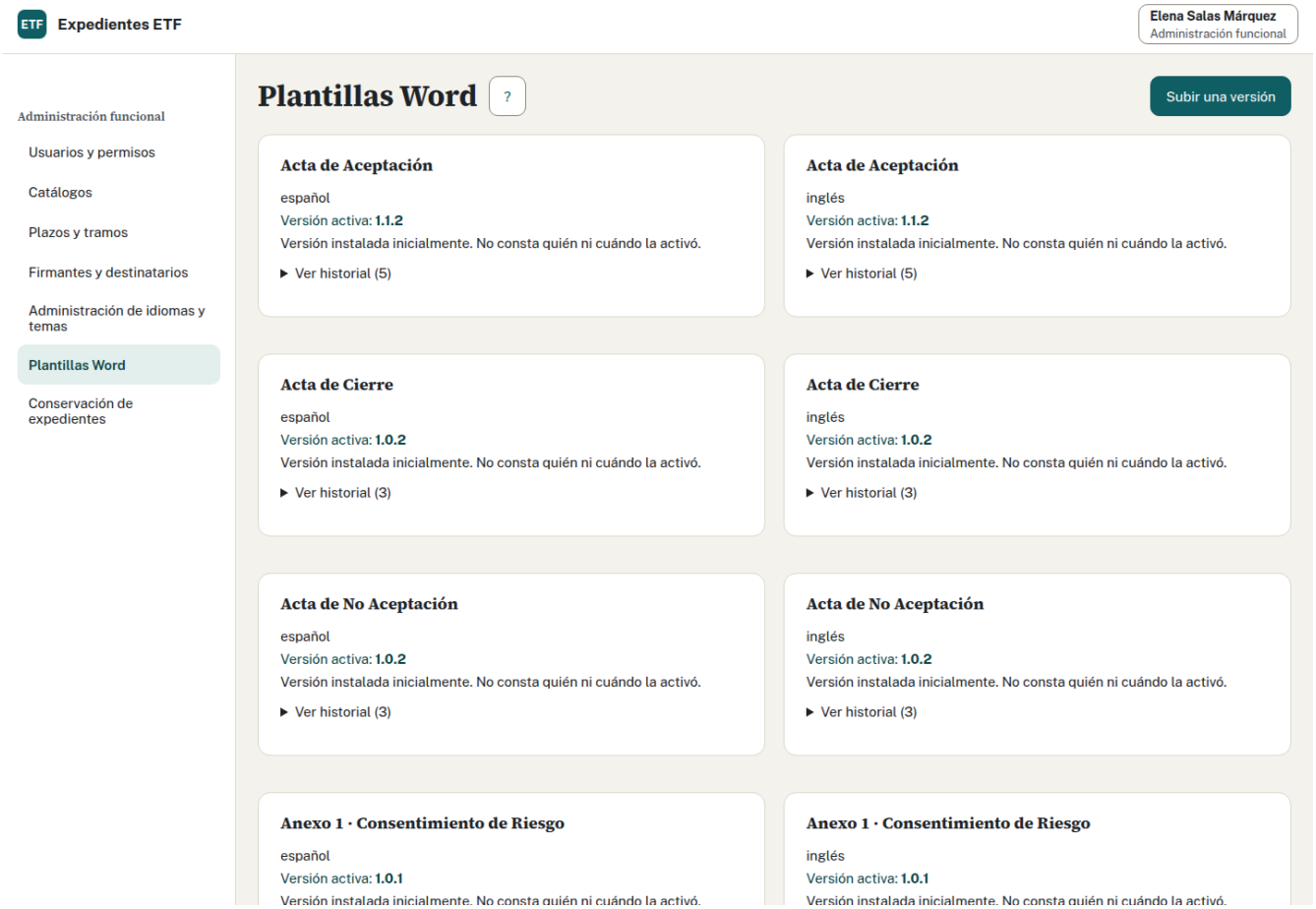
```
sudo install -d -m 0750 -o 10001 -g 10001 /srv/etf/paquetes
sudo install -d -m 0750 -o 10001 -g 10001 /srv/etf/paquetes/idiomas
sudo install -d -m 0750 -o 10001 -g 10001 /srv/etf/paquetes/temas
sudo cp -a idiomas/. /srv/etf/paquetes/idiomas/
```

```
sudo cp -a temas/. /srv/etf/paquetes/temas/
sudo chown -R 10001:10001 /srv/etf/paquetes
componer config --quiet
```

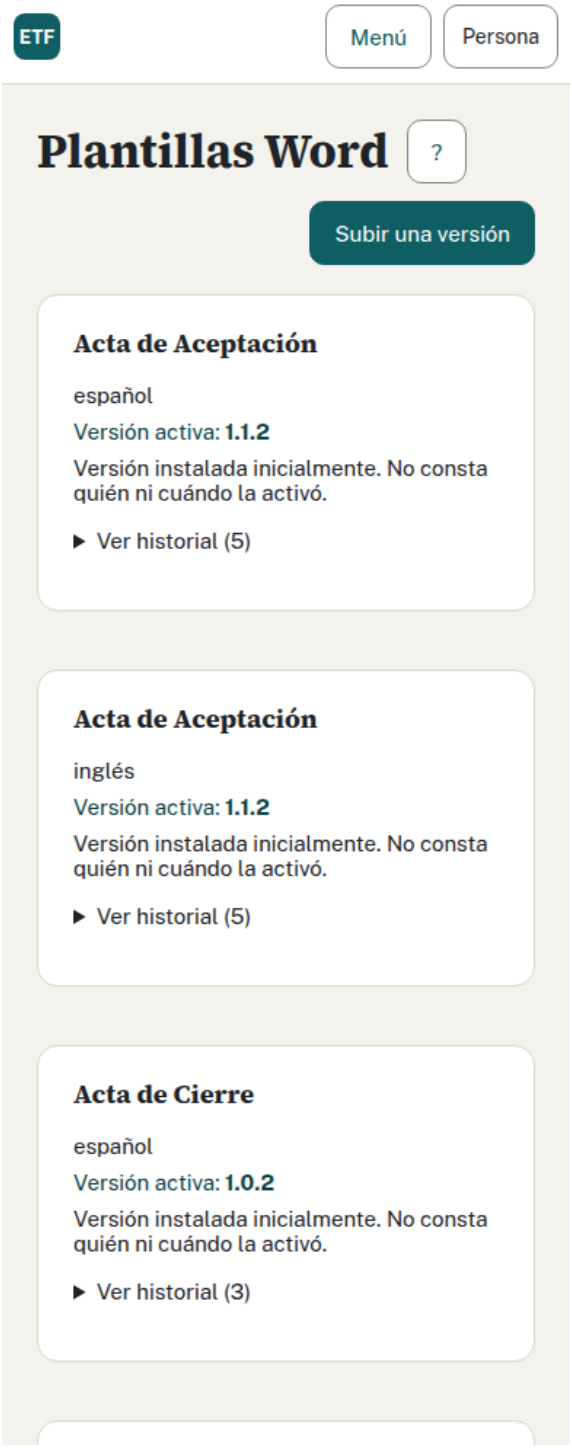
Comprueba el permiso de lectura y escritura del UID 10001 y, si el host aplica controles adicionales a los montajes, su política específica. No uses `chmod 777`. Estos comandos de copia inicial no son un procedimiento de actualización: en un almacenamiento ya usado podrían reemplazar versiones administradas.

Administración publica idiomas y temas desde Paquetes, y Word desde Plantillas. Cada publicación crea una versión inmutable; su activación y autoría se registran en la base. No edites el archivo activo ni borres versiones antiguas que una emisión o Memoria pueda necesitar. La base guarda referencias; restaurarla sin los archivos de la misma copia puede dejar descargas inutilizables.

Al actualizar, conserva todas las versiones locales y añade sólo los recursos que exija esa entrega, siguiendo sus notas. Comprueba que las rutas previstas en las migraciones están presentes antes de ejecutarlas. Las reservas de la imagen sirven para recuperaciones limitadas de textos y temas; no sustituyen una copia de plantillas administradas ni garantizan recuperar todas las referencias.



Plantillas Word en escritorio: Elena Salas consulta las versiones disponibles y las activas en la demostración local, a 1440 píxeles.



Plantillas Word en móvil: la misma lista permite comprobar la lectura de versiones y los controles a 390 píxeles.

A.4 LDAPS y certificado

Sólo se admite `ldaps://`; el directorio utiliza TCP 636 y un certificado válido para el nombre configurado. El archivo PEM debe contener la autoridad de confianza. Confirma DNS, ruta y hora desde el servidor y desde la red que usará app. Para comprobar la cadena desde el servidor, sustituye las variables de esta sesión por el host y certificado aprobados:

```
openssl s_client -connect "$ETF_AD_HOST:636" \
  -servername "$ETF_AD_HOST" -verify_hostname "$ETF_AD_HOST" \
  -CAfile /etc/etf/certificados/ad-ca.pem -verify_return_error < /dev/null
```

`ETF_AD_HOST` es una variable de esta orden de diagnóstico, no una opción de app. Exige validación correcta y confirma después el acceso real con una cuenta habilitada. Esta prueba del host no demuestra conectividad desde el contenedor. El formato de bind usa `{usuario}`; el adaptador busca `sAMAccountName` y exige una única entrada

y `objectGUID`. Informática debe confirmar con desarrollo que la búsqueda corresponde al principal autenticado (riesgo R-06). No desactives la comprobación TLS para salvar una CA incorrecta.

Al renombrar una cuenta, los perfiles siguen su `objectGUID`. Una cuenta nueva con un login reutilizado no debe heredar permisos. Comprueba ambos casos en preproducción. Si AD deshabilita una cuenta, retira también el acceso en la app: una sesión ya abierta puede durar hasta el máximo configurado.

SEG1 fija 30 minutos sin actividad y 8 horas de duración absoluta por defecto. Ambos plazos se configuran con las variables anteriores. La inactividad debe superar dos minutos y no superar el máximo; el máximo tiene un tope técnico de 24 horas. La pantalla avisa dos minutos antes, permite continuar dentro del máximo y vuelve a la entrada al caducar. Los datos guardados se conservan.

A.5 Proxy HTTPS

El navegador debe usar el origen HTTPS exacto de `ETF_HTTP_ORIGEN`, sin ruta. El proxy termina TLS y reenvía a la publicación local de app. Conserva `Host`, `Origin`, cookies y cabeceras CSRF; sustituye `X-Forwarded-For` por la dirección real del cliente. Declara sólo las redes del proxy en `ETF_HTTP_PROXIES`, como CIDR separados por comas. No confíes en todas las redes ni en cabeceras del cliente.

Restringe acceso a red corporativa, provincial y VPN. Configura el certificado, HSTS y los límites por cliente en el proxy acordado; excluye la caché de respuestas de API, sesiones, cifras y descargas. Las cookies son `Secure`, `HttpOnly` y `SameSite=Strict`. El puerto 18083 queda en loopback si proxy y app comparten host. Un proxy remoto requiere conexión privada revisada, sin abrir ese puerto al público.

Coordina los límites de cuerpo y tiempos con las subidas admitidas por app: un límite menor en el proxy produce un rechazo antes del mensaje del antivirus o lector. Verifica subida y descarga de un Word inventado, petición de modificación con origen correcto y rechazo desde origen distinto. No guardes cuerpos de peticiones, tokens ni contraseñas en registros del proxy.

A.6 Puesta en servicio

Tras preparar roles, migrar y arrancar, comprueba por HTTPS la entrada del primer administrador, el alta de perfiles, un expediente de cada equipo y una descarga. Prueba que Administración no accede a fichas y que Consulta sólo obtiene cifras. Usa datos inventados en preproducción. El login del primer administrador sólo se aplica una vez: no recupera permisos retirados al cambiar la variable o reiniciar.

No hay envío de correo ni variables SMTP. No se conecta con un registro externo ni con firma electrónica. Sus actuaciones se hacen fuera de esta aplicación. La lista de puesta en producción debe quedar aceptada antes de introducir datos reales.

Anexo B. Copias, auditoría y conservación

Autor: Expedientes ETF. Revisión: 14 de octubre de 2026.

Volver al manual. Usa la función `componer` definida allí. La copia incluye base y archivos de paquetes del mismo momento, con app parada.

A. Cifrar y comprobar una copia

Informática decide el destino fuera del servidor y la herramienta corporativa. Si utiliza GnuPG local, este procedimiento cifra un conjunto ya tomado según §5 del manual. Requiere `gpg`, `tar` y `sha256sum`. El directorio de trabajo debe estar en almacenamiento cifrado, con permisos privados: hasta cifrarlo contiene datos en claro. La clave de copia queda en `/etc/etf/copia.clave`, con permiso 0600, fuera de Git y fuera de la copia. Custodia una forma de recuperarla por separado; perder esa clave impide restaurar.

1. Para app y cierra la entrada en el proxy. Toma `etf.dump` y comprueba su índice con las órdenes del manual. Copia los paquetes completos mientras sigue parada.
2. Para los montajes del anexo A, crea `paquetes.tar` y el inventario privado:

```
sudo tar -C /srv/etf/paquetes -cpf "$ETF_COPIA_DIR/paquetes.tar" idiomas temas
git rev-parse HEAD > "$ETF_COPIA_DIR/version.txt"
componer images --format json > "$ETF_COPIA_DIR/imagenes.json"
(
  cd "$ETF_COPIA_DIR"
  sha256sum etf.dump paquetes.tar version.txt imagenes.json > SHA256SUMS
)
```

3. Guarda también la configuración externa necesaria en su custodia cifrada autorizada. Los secretos y claves privadas tienen custodia separada. Conserva el sello de auditoría independiente y el inventario de bajas y equipos que necesitarás reconciliar tras restaurar.
4. Cifra el conjunto. `$ETF_DESTINO_COPIAS` debe ser el destino aprobado fuera del servidor, montado y accesible; usa una ruta nueva para cada copia. Estas variables pertenecen al procedimiento, no configuran app. Activa parada por error en la sesión de operación antes de ejecutar:

```
set -e
umask 077
tar -C "$ETF_COPIA_DIR" -cf "$ETF_COPIA_DIR/conjunto.tar" \
  etf.dump paquetes.tar version.txt imagenes.json SHA256SUMS
gpg --batch --pinentry-mode loopback \
  --passphrase-file /etc/etf/copia.clave --symmetric --cipher-algo AES256 \
  --output "$ETF_COPIA_DIR/conjunto.tar.gpg" "$ETF_COPIA_DIR/conjunto.tar"
(
  cd "$ETF_COPIA_DIR"
  sha256sum conjunto.tar.gpg > conjunto.tar.gpg.sha256
)
install -d -m 0700 "$ETF_DESTINO_COPIAS"
cp "$ETF_COPIA_DIR/conjunto.tar.gpg" "$ETF_DESTINO_COPIAS/conjunto.tar.gpg.part"
mv "$ETF_DESTINO_COPIAS/conjunto.tar.gpg.part" "$ETF_DESTINO_COPIAS/conjunto.tar.gpg"
cp "$ETF_COPIA_DIR/conjunto.tar.gpg.sha256" "$ETF_DESTINO_COPIAS/"
(
  cd "$ETF_DESTINO_COPIAS"
  sha256sum -c conjunto.tar.gpg.sha256
)
```

5. Descifra una copia recuperada del destino en una máquina aislada. El directorio de recuperación debe ser nuevo, privado y cifrado. No extraigas un archivo de procedencia desconocida. Verifica el cifrado y las sumas antes de restaurar:

```
install -d -m 0700 "$ETF_RECUPERACION"
gpg --batch --pinentry-mode loopback \
  --passphrase-file /etc/etf/copia.clave --decrypt \
  --output "$ETF_RECUPERACION/conjunto.tar" \
  "$ETF_DESTINO_COPIAS/conjunto.tar.gpg"
tar -C "$ETF_RECUPERACION" -xf "$ETF_RECUPERACION/conjunto.tar"
(
  cd "$ETF_RECUPERACION"
  sha256sum -c SHA256SUMS
)
```

Las sumas detectan cambios de contenido; la verificación del contenedor cifrado comprueba su integridad. Restaurar sigue las órdenes de §5 del manual: preparar roles, recuperar base y paquetes, invalidar sesiones, reconciliar permisos y retiradas de datos, comprobar auditoría y realizar el recorrido antes de abrir. No ejecutes

migraciones nuevas sobre la copia para probar una versión anterior. Registra fecha, versión, tamaño, destino, suma, resultado y tiempo de recuperación; no escribas la clave en la evidencia. Retira las copias de trabajo en claro según el procedimiento de almacenamiento cifrado de Informática.

El ensayo F5.05 y la repetición MANSIS comprueban la recuperación lógica. El script no cifra ni traslada fuera del servidor. Informática debe ensayar ese circuito completo, incluida recuperación de claves, antes de producción y repetirlo tras cambios que afecten a base o paquetes. Configura una alarma si falla la copia diaria o si la última válida supera un día.

B. Registros y cadena de auditoría

Los registros técnicos salen en JSON por stdout/stderr. Docker rota tres archivos de 10 MB por servicio. Puedes consultar sin volcar secretos:

```
componer logs --since 30m --tail 100 app migrar preparar-roles
componer ps -a
```

El controlador `local` no es un archivo de texto para abrir directamente en `/var/lib/docker`. Usa la interfaz de Docker. Limita también el acceso y la retención del proxy y del colector corporativo. Para una incidencia conserva hora, versión, servicio, clave de error y estado HTTP; no incluyas nombres, contenidos de expediente, cookies, contraseñas ni cuerpos de peticiones.

La auditoría funcional está en PostgreSQL. Las lecturas y escrituras registran actor, acción, identificador y resultado, con huellas encadenadas. Si no se puede confirmar la auditoría, no se entregan los datos. Informática no debe corregir una cadena editando o borrando filas ni restaurar sólo la tabla de eventos.

Administración funcional exporta JSON desde Auditoría con su permiso específico. El comprobador lee ese archivo local, no conecta con la base ni lo modifica. Desde la raíz, con Go disponible:

```
go build -o "$ETF_HERRAMIENTAS/comprobar-auditoria" ./cmd/comprobar-auditoria
"$ETF_HERRAMIENTAS/comprobar-auditoria" "$ETF_AUDITORIA_JSON"
"$ETF_HERRAMIENTAS/comprobar-auditoria" "$ETF_AUDITORIA_JSON" \
  "$ETF_SELLO_ID" "$ETF_SELLO_HUELLA"
```

Crea antes `$ETF_HERRAMIENTAS` en una ruta privada. Las variables anteriores son rutas y sello del procedimiento. El primer modo comprueba coherencia interna; no demuestra que nadie rehízo toda la cadena. El segundo compara también ID y huella final con un sello custodiado fuera de esa exportación. Para un tramo:

```
"$ETF_HERRAMIENTAS/comprobar-auditoria" "$ETF_AUDITORIA_JSON" \
  "$ETF_ID_ANTERIOR" "$ETF_HUELLA_ANTERIOR" "$ETF_SELLO_ID" "$ETF_SELLO_HUELLA"
```

Salida 0: `auditoria.cadena_coherente` o `auditoria.sello_externo_coincide`. Salida 1: verificación fallida; salida 2: uso, punto o archivo inválido. Conserva la exportación y el resultado con acceso restringido; los vínculos usuario-expediente siguen siendo datos personales. El sellado diario externo no está automatizado por Compose: sigue pendiente R-05. No extraigas la huella final del mismo JSON para presentarla como sello independiente.

C. Monitorización y salud

`GET /salud` es público en la red que deja pasar el proxy. Con base disponible responde HTTP 200 y `{"estado":"ok","base":"ok"}`; puede añadir `avisos`. Con base no disponible responde HTTP 503 y `{"estado":"degradado","base":"no_disponible"}`. La comprobación de base tiene un límite de dos segundos. Docker usa esta ruta para la salud de app; no hay rutas `/vivo` o `/listo` separadas en esta versión.

```
curl --fail --max-time 5 http://127.0.0.1:18083/salud
componer ps -a
componer stats --no-stream
```

Ajusta el puerto si lo cambiaste. Comprueba también la URL HTTPS desde una red autorizada: el loopback no prueba proxy, DNS o certificado. PostgreSQL usa `pg_isready` en su healthcheck, que no demuestra autenticación ni permisos; la prueba de app y el migrador completan esa comprobación. ClamAV comprueba `PONG`, que no acredita la actualidad de sus firmas.

Control para Informática	Qué debe alertar y cómo comprobar después
HTTP interno y HTTPS	503, errores de acceso o tiempos crecientes; comprobar base, proxy y DNS
CPU, memoria y reinicios	Reinicios o límites alcanzados; revisar `stats`, estado y logs sin ampliar a ciegas

Disco de base, paquetes y copias	Espacio insuficiente o crecimiento anormal; nunca borrar archivos PostgreSQL a mano
AD	Fallo de conexión o certificado; probar LDAPS y entrada autorizada, sin almacenar contraseña
Certificados HTTPS y CA de AD	Caducidad próxima o cadena inválida; renovar y probar antes de vencer
Antivirus	Falta de respuesta o firmas antiguas; reponer suministro local y ensayar rechazo
Copias	Tarea fallida, recepción incompleta o última copia válida de más de un día
Auditoría	Falta de sello externo o fallo del comprobador; preservar evidencia y escalar
Paquetes	Errores de lectura o publicación; comprobar referencias, permisos y archivos de la misma versión

Informática fija frecuencia, umbrales, destinatarios y guardias para estos controles. Compose no instala un colector, panel de métricas, alarmas, programador de copias ni supervisión de la caducidad TLS. La salud tampoco informa de última copia, fecha de firmas o acceso real AD, aunque el TRD los prevé.

D. Conservación y retirada de datos personales

La función está implementada; no es una tarea de borrar filas directamente. El plazo inicial es 25 años desde el cierre y se configura desde Plazos y tramos con clave `conservacion` y unidad `anos`. El código admite de 1 a 200 años; cambiar el plazo requiere decisión autorizada, nueva versión y revisión de propuestas. La marca se recalcula al cerrar o consultar conservación. No hay que instalar un cron que invoque SQL de borrado ni adelantar el reloj de producción.

1. Confirmar con el responsable del producto el criterio aprobado para la aplicación y el tratamiento de copias, archivos descargados y vínculos de auditoría. Su validación sigue pendiente; este procedimiento no la sustituye.
2. Administración funcional entra en Conservación. La lista muestra número, cierre, fin del plazo y estado; no da acceso a nombres ni fichas.
3. Una persona revisa número, plazo y alcance y confirma la primera revisión. Otra persona de Administración distinta debe confirmar la anonimización. Informática prepara el servicio y el respaldo; no se concede un perfil para ejecutar esa decisión por su cuenta.
4. El servidor exige expediente cerrado, plazo cumplido, revisión vigente y ausencia de seguimiento activo. Si cambian expediente o catálogo, actualizar la lista y revisar otra vez. No repetir una petición antigua para saltar el conflicto ni llamar directamente a funciones SQL.
5. La confirmación retira nombres, contacto y textos libres, también de las versiones históricas, y los recibos que reproduzcan esos datos. Incluye la retirada de datos identificativos en Evaluación y Documentos dentro de la misma transacción. Se conservan códigos, cifras, fechas necesarias para estadísticas y vínculos de auditoría; el expediente queda protegido frente a nuevas ediciones. La cadena de auditoría permanece íntegra.
6. Registrar el resultado y comprobar «Datos personales retirados. Se conservan las cifras y los vínculos de auditoría.». Una retirada confirmada no tiene botón de deshacer. No restaurar una copia antigua para revertirla.

Aunque la pantalla diga «Anonimizado», las fechas y vínculos conservados requieren el criterio del DPD; no se deben tratar como datos totalmente anónimos. Las narraciones ya cerradas de Memoria y archivos descargados tienen su propio alcance de revisión: no prometas que esta acción elimina cualquier texto de toda la aplicación o de los equipos.

Tras restaurar una copia anterior, mantén la entrada cerrada y reconcilia también las retiradas realizadas desde su fecha. El estado recuperado puede contener de nuevo datos retirados. Conserva un registro restringido de esas operaciones para que las personas autorizadas puedan repetirlas antes de abrir. La retención de copias y su

retirada segura se acuerdan con Informática y el responsable del producto; 25 años de expediente no significa 25 años para cada copia.

Anexo C. Resolución de problemas

Autor: Expedientes ETF. Revisión: 14 de octubre de 2026.

Volver al manual. Anota hora, versión, servicio y clave. Comprueba `componer ps -a`, salud y registros acotados antes de reiniciar. Estos textos proceden de los catálogos en castellano; las claves son las que devuelve o registra el código. No adjuntes datos personales ni credenciales a soporte.

C.1 Acceso y sesión

Clave y mensaje real	Comprobación y resolución
`identidad.configuracion_invalida`: «El acceso aún no está disponible. Contacta con Informática.»	Revisar que el contenedor recibe origen, CA PEM, URL LDAPS, DN, formato de bind y duración explícita de sesión. Consultar el anexo de configuración; una variable sólo en el archivo externo no llega al contenedor sin `environment`
`identidad.directorio_no_disponible`: «El servicio de acceso de la entidad no responde. No puedes entrar ahora. Prueba más tarde.»	Comprobar DNS, salida privada del contenedor a 636, certificado, hora y disponibilidad del controlador. No cambiar a LDAP sin cifrar ni crear una entrada local alternativa
`identidad.credenciales_invalidas`: «No se ha podido entrar con ese usuario y contraseña. Compruébalos y vuelve a intentarlo.»	Confirmar login permitido y contraseña sin registrarla. Si una cuenta conocida falla, revisar con Informática formato de bind y lectura de `objectGUID`. No conceder perfiles para resolver credenciales
`identidad.intentos_limitados`: «Se han recibido demasiados intentos de acceso. Espera unos minutos y vuelve a intentarlo.»	No repetir intentos automatizados. El límite de fallos es cinco por usuario y treinta por IP en quince minutos; comprobar que proxy sustituye la cabecera y está declarado en `ETF_HTTP_PROXIES`
`identidad.sesion_no_valida`: «Tu sesión ha caducado. Vuelve a entrar.»	Entrar de nuevo. La sesión vence a los treinta minutos sin actividad o al máximo absoluto configurado. Si ocurre tras restaurar, la revocación es parte de la recuperación
`identidad.csrf_no_valido`: «No se ha podido confirmar la petición. Recarga la página y vuelve a intentarlo.»	Recargar y revisar origen y cabeceras del proxy. Un reinicio cambia la clave CSRF. Recuperar el resultado de operaciones idempotentes antes de repetir una creación
Pantalla de pendiente de alta	AD aceptó la cuenta, pero falta perfil. Administración funcional asigna perfil y equipo. Informática no corrige esto reiniciando ni editando permisos SQL

Si una modificación da HTTP 409, otra operación cambió la versión. Actualiza y revisa; no repitas con una versión antigua. Si da 403, comprueba perfil vigente y equipo con Administración. El acceso de una persona de equipo a otro equipo está denegado por diseño.

C.2 Base, migraciones y preparación de roles

Registro o clave real	Comprobación y resolución
`configuracion.reserva`, con nombre de variable	La configuración usa una reserva. Consultar la variable nombrada, sin imprimir su valor secreto
`postgres.configuracion_invalida`	En app revisar usuario `etf_app`, contraseña no vacía, host, puerto, máximo de conexiones y modo TLS. En preparación de roles puede indicar membresía inesperada; detener actualización y revisar con desarrollo, sin retirar membresías a ciegas
`postgres.no_disponible` o `/salud` con `base: no_disponible`	Revisar PostgreSQL, disco, red privada y autenticación. No borrar el volumen ni sembrar de nuevo. Si hay recuperación, seguir §5 del manual
`migracion.configuracion`	El migrador necesita host, puerto, base y su contraseña propia. No darle credenciales de app ni instalador
`migracion.postgres`	Revisar conexión autenticada y salida acotada del servicio. Un `pg_isready` correcto no demuestra que el migrador pueda entrar
`migracion.rol`	Se intentó ejecutar con otro usuario. Usar servicio `migrar` y `etf_migrador`; no ejecutar SQL manualmente
`migracion.huella`	Historial y artefacto no coinciden. Conservar copia y versión y avisar a desarrollo. No

	editar la huella ni el SQL ya aplicado
`migracion.retroceso`	Falta una migración de número inferior a otra ya aplicada en su módulo. Detener despliegue y solicitar una entrega con orden corregido. No borrar historial ni renumerar la base
`migracion.dependencia`, `migracion.historial` o `migracion.estado_previo`	Estado o dependencias incompatibles con la entrega. Conservar salida y artefacto, comprobar copia y consultar desarrollo. Cada paso confirma su transacción: un fallo no deshace los anteriores
`migracion.aplicada.<modulo>.<numero>`	Paso aplicado. Verificar salida final 0 y salud antes de abrir
`migracion.existente.<modulo>.<numero>`	Paso ya aplicado y compatible. No es un error ni exige repetir SQL

`preparar-roles` se ejecuta antes de `migrar`, incluso con volumen antiguo. Si su salida no es 0, no arranques migración ni app para saltar esa puerta. Verifica socket temporal, UID/GID 70:70 y contraseñas del archivo privado. No uses `componer run --no-deps migrar`: omite la preparación necesaria. La evidencia FX2 detalla instalación limpia y actualización de roles anteriores.

Si Docker rechaza publicar el puerto local porque ya está ocupado, comprueba qué servicio lo usa. Elige un puerto libre y ajusta proxy y comprobaciones; para una demo nueva puedes usar `ETF_DEMO_PUERTO`. Un solapamiento de subred Docker se resuelve con rangos privados libres, sin parar servicios de otros proyectos.

C.3 Antivirus, paquetes y documentos

Los anexos y las actas de carga histórica admiten DOCX, ODT y PDF, hasta 10 MB. Se leen sin conservar el archivo y una persona confirma los datos. La aplicación no valida la autenticidad de la firma de un PDF ni extrae texto de un escaneado. Un documento sin texto legible requiere completar los datos a mano.

Clave y mensaje real	Comprobación y resolución
`antivirus.configuracion_invalida`: «La revisión antivirus no está disponible. Contacta con Informática.»	Revisar dirección `clamav:3310` y configuración; no publicar 3310 al exterior
`antivirus.no_disponible`: «No se ha podido revisar el archivo con el antivirus. Inténtalo de nuevo.»	Comprobar daemon, memoria, `PONG` y firmas. El anexo admite continuar con aviso según la decisión vigente; paquetes, plantillas y hojas requieren revisión satisfactoria
`paquete.antivirus_no_disponible`: «No se ha podido completar la revisión antivirus. El paquete no se ha activado. Inténtalo de nuevo.»	Mantener activa la versión anterior; restablecer antivirus antes de subir de nuevo
`paquete.infectado`: «El antivirus ha detectado contenido peligroso. El paquete no se puede activar.»	Rechazar el archivo y seguir el procedimiento de incidente. No desactivar antivirus ni instalarlo a mano
`paquete.archivo_invalido`: «El paquete no cumple los requisitos de formato, contenido o tamaño. Revisa el archivo antes de volver a subirlo.»	Pedir a Administración un paquete válido del tipo admitido; no ampliar límites para aceptar formatos peligrosos
`idiomas.no_disponibles` o `tema.no_disponible`	Revisar rutas y permisos del UID 10001, referencia activa y archivos. Recuperar el paquete correspondiente; una reserva de imagen no recupera versiones administradas
`paquete.limpieza_pendiente`	La limpieza de archivos huérfanos no pudo completarse. Revisar almacenamiento y permisos; no borrar versiones referenciadas para silenciarlo
`documento.plantilla_no_disponible`: «No hay una plantilla válida para este documento en el idioma elegido.»	Administración revisa tipo, idioma, vigencia y versión activa. Informática comprueba archivos y referencias de la misma copia
`documento.plantilla_alterada`: «La plantilla ha cambiado sin publicar una versión	Conservar evidencia y recuperar la versión íntegra o publicar otra desde la app. No actualizar la huella en la base

nueva. Avise a Administración.»

`documento.firmante_no_disponible`: «No hay un firmante vigente configurado para este documento.»	Administración revisa el firmante y su vigencia; no es un fallo de Docker
`documento.reproduccion_no_disponible`: «No se puede reproducir exactamente la descarga anterior. Se conserva el recibo de emisión. Solicite una emisión nueva.»	Comprobar historial y plantilla necesaria. Si ya no es reproducible, la persona solicita nueva emisión; no sustituir silenciosamente datos o versión

Si tras una subida nada aparece en Administración, comprueba primero respuesta, versión activa y permisos de publicación. El montaje base es de sólo lectura; la publicación en producción necesita el almacenamiento del anexo A. No cambies permisos del repositorio entero.

Si Docker marca ClamAV saludable pero la firma es antigua, repón el suministro local aprobado. Cambiar imagen no reemplaza el volumen de firmas existente. No elimines ese volumen en producción sin tener preparada su reposición.

C.4 Auditoría, conservación y recuperación

Clave o mensaje real	Actuación
`auditoria.cadena_coherente`	Comprobación interna correcta; falta el sello externo para acreditar el punto custodiado
`auditoria.sello_externo_coincide`	Cadena y sello independiente coinciden; conservar resultado y exportación
`auditoria.sello_externo_no_coincide` o `auditoria.ancla_externa_no_coincide`	No abrir tras restauración sin aclararlo. Verificar tramo, sello y copia correctos; preservar archivos y escalar, sin regenerar el sello desde el JSON
`conservacion.conflicto`: «El expediente o el plazo ha cambiado. Actualiza la lista y revisa de nuevo.»	Actualizar lista; la revisión anterior puede haber quedado invalidada
`conservacion.no_permitida`: «No se cumplen las condiciones para confirmar. Actualiza la lista y revisa el estado.»	Comprobar plazo cumplido, estado cerrado, seguimiento terminado y segunda persona distinta
`conservacion.sin_permiso`: «Tu sesión no permite esta acción. Vuelve a entrar con un perfil de Administración.»	Administración realiza la operación autorizada; Informática no fuerza SQL

Una restauración que devuelve el acceso pero pierde plantillas está incompleta. Mantén la entrada cerrada y recupera base y paquetes del mismo conjunto. Tras una copia antigua, revoca sesiones y reconcilia permisos, bajas, traslados y retiradas de datos posteriores. No borres la auditoría ni repitas la siembra.

Si el disco se llena o un contenedor reinicia por falta de memoria, para escrituras, conserva registros y amplía capacidad o retira sólo copias y logs según el plazo aprobado. No borres archivos del volumen de base. «Servicio no disponible» puede ser consecuencia de una auditoría no confirmada, aunque PostgreSQL acepte conexiones; revisa logs y permisos antes de reiniciar.

En Windows, sigue la guía del paquete: comprueba motor WSL2 activo, suma de paquete y puerto guardado. No uses «Reiniciar» para resolver una parada si quieres conservar datos. El paquete no convierte el PC en un servidor de producción.

Autor: Expedientes ETF. Fecha: 14 de octubre de 2026. Rama: `manual-sistemas`. Volver al manual.

D.1 Alcance

Manual ampliado y contrastado con TRD, Compose, Dockerfile, configuración real, comprobador de auditoría, conservación y catálogos de errores. Incluye anexos de configuración, cifrado y operación, diagnóstico y este registro; PDF con autoría y enlaces locales. Las evidencias anteriores F5.05, FX2 y WIN1 se conservan.

Diferencia respecto al arranque previsto en TRD: la salud actual comprueba la conexión PostgreSQL, no una versión mínima del esquema ni todos los conectores. El migrador controla historial y huellas antes de arrancar. El manual distingue las funciones presentes de las previstas.

No se ha accedido a producción, AD corporativo ni otros proyectos de datos. Todas las personas y expedientes usados son inventados. No se ha ensayado el proxy corporativo, la recepción de una copia fuera del servidor ni su custodia de claves. Se ha comprobado el cifrado y descifrado local con GnuPG AES256 del volcado y paquetes inventados, con clave temporal privada y comparación exacta del conjunto. Es una opción local para Informática; la recuperación corporativa completa sigue pendiente.

Configuración del anexo A renderizada con Compose y variables inventadas, sin crear servicios de producción ni mostrar valores de entorno:

```
MANSIS-COMPOSE-OK: archivo adicional válido; paquetes escribibles, CA de sólo lectura y preparación previa conservadas.
```

D.2 Restauración

```
ETF_DEMO_PUERTO=18653 make demo
python3 -B scripts/ensayar-restauracion.py
```

El primer ensayo confirmó datos y secuencias idénticos, pero detectó una diferencia de permisos de paquetes: BusyBox `tar` aplica la máscara del proceso incluso con `-p`, pasando archivos 0664 a 0644 y directorios 0775 a 0755. No hubo pérdida de contenido. La copia privada se conservó y se recuperó con su contenido y permisos originales antes de repetir.

Tras integrar las mejoras de la demo, otra repetición detectó doce recursos anteriores con UID/GID 1000 que la extracción como app convertía en 10001. La base, el contenido y los permisos coincidían. Se conservó la copia y se recuperaron los propietarios originales antes de repetir.

El ensayo ahora usa el servicio puntual `incorporar` para recuperar paquetes: no tiene red, sólo monta sus dos volúmenes y dispone de las capacidades de propiedad de archivos ya previstas por la demo. La app sigue como UID 10001 sin privilegios. Fija `umask 000` únicamente durante la extracción de su propio archivo privado recién creado. Mantiene la comparación estricta de contenidos, propietarios y permisos; no oculta la diferencia. El ajuste no cambia los permisos que lleva la copia ni admite archivos externos. Resultado de la repetición:

```
RESTAURACION-OK: datos, secuencias y paquetes idénticos
F5.05-OK: copia, borrado, restauración, siete accesos y recorrido Chrome
```

Prueba local de cifrado de ese conjunto, con GnuPG, clave temporal privada y comparación SHA-256 tras descifrar:

```
MANSIS-CIFRADO-OK: GnuPG AES256; descifrado, dump y paquetes idénticos; sólo datos inventados locales.
```

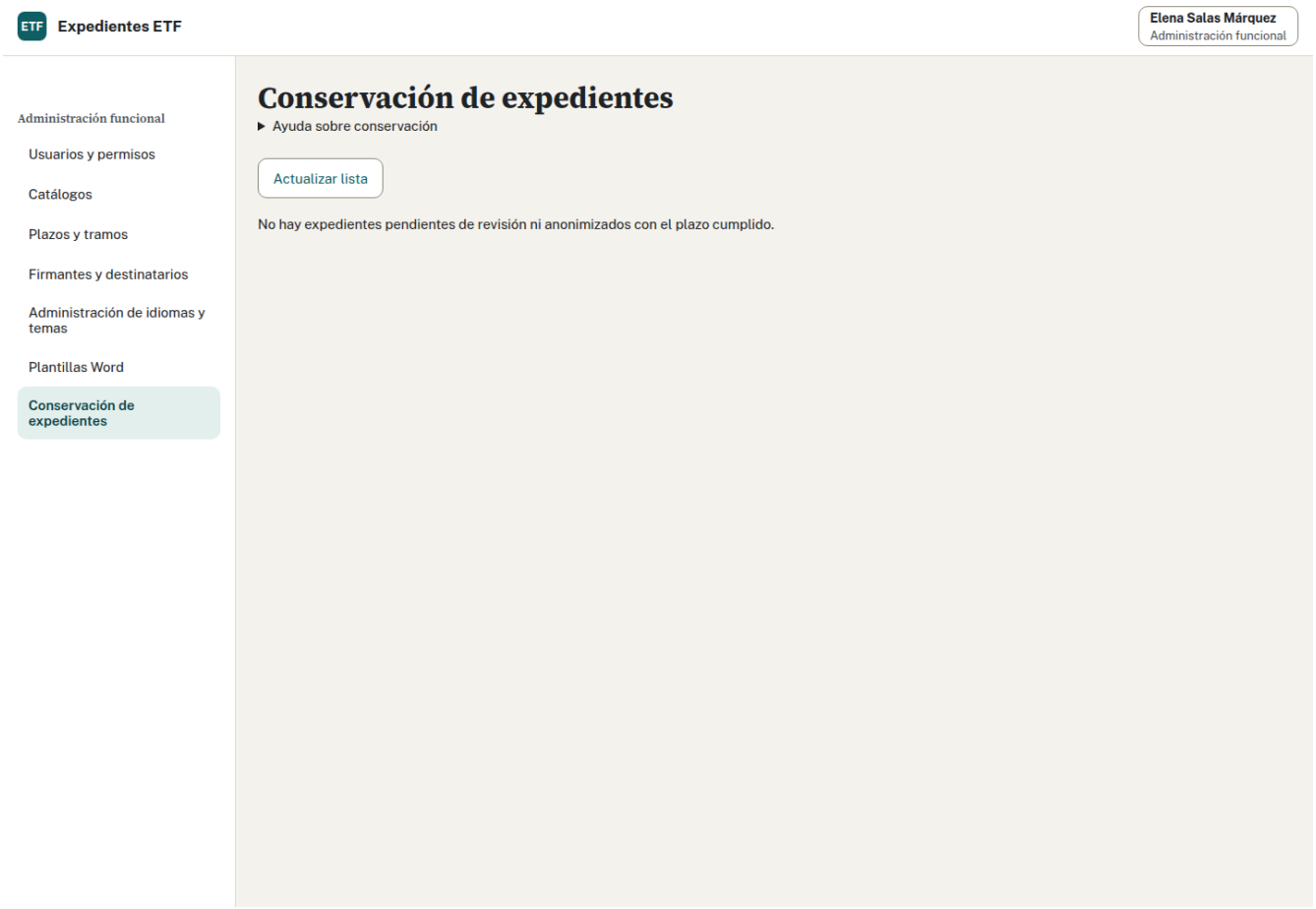
D.3 Capturas

Con la demo recuperada y las cuentas iniciales:

```
node docs/sistemas/capturar.mjs
```

Chrome del sistema y Playwright; Elena Salas, Administración funcional. El script lee el puerto y credenciales privados de esta demo, consulta Plantillas a 1440 y 390 píxeles, comprueba ausencia de desbordamiento y captura Conservación a 1440. La lista de conservación está vacía porque ningún caso de la demo ha cumplido el plazo; no se adelanta el reloj ni se simula una confirmación. No se publican credenciales ni expedientes reales.

```
MANSIS-CAPTURAS-OK: Plantillas 1440/390; Conservación 1440; salud 200; sin errores JavaScript.
```



Conservación en escritorio: Elena Salas ve el estado vacío real y el enlace a los plazos, sin nombres de familias ni expedientes vencidos.

D.4 PDF, enlaces y regresión

```
TMPDIR=/dev/shm/etf/tmp python3 -B docs/manuales/exportar.py \
  --manual sistemas --salida docs/sistemas
python3 -B scripts/ci/enlaces.py
make ci
```

El exportador permite seleccionar Sistemas y mantiene por defecto los tres PDF anteriores. La selección repetible de Administración y Sistemas, incluida una repetición de Administración, generó cada PDF una sola vez. La comprobación compara sus documentos ODT con el exportador previo y genera esos PDF en una carpeta temporal, sin modificar los otros manuales. Sistemas incorpora anexos, capturas, líneas de órdenes sin unir y metadatos de Expedientes ETF. Los enlaces a los anexos incluidos son internos; los enlaces a otros archivos conservan rutas relativas al árbol entregado. Resultado:

```
EXPORTADOR-REGRESION-OK: contenido ODT idéntico para profesionales, coordinación y administración.
EXPORTADOR-SISTEMAS-OK: XML, anexos, tablas, órdenes, autor, enlaces internos y textos alternativos.
PDF-OK: sistemas.pdf
MANSIS-PDF-ENLACES-OK: 18 enlaces externos relativos, todos con destino local existente.
MANSIS-PDF-OK: anexos, órdenes, mensajes reales y capturas incluidos; autor Expedientes ETF.
Markdown: 173 documentos, 949 enlaces locales, 15 enlaces externos sin consulta de red, 0 errores.
CI mínima completada.
```

Se ejecutó `make ci` completo antes y después de integrar las actas ODT; ambas ejecuciones terminaron correctamente. Tras integrar la actualización de la demo y resolver el exportador compartido se repitió la CI completa, también verde. La CI incluye `go vet ./...`, `go test ./...`, frontend, textos, temas, migraciones PostgreSQL y recorridos con Chrome. La revisión local de los procedimientos cubre secretos fuera de Git, separación de roles, restauración sin sesiones válidas, reconciliación de permisos y conservación, y límites del sello de auditoría. No cierra los riesgos que necesitan infraestructura y validación de Informática.

`main` integrado antes de la entrega: `5dd23bc`; conflicto del exportador resuelto conservando ambas capacidades. La demo se para conservando los datos inventados y se retiran los temporales de estas pruebas.